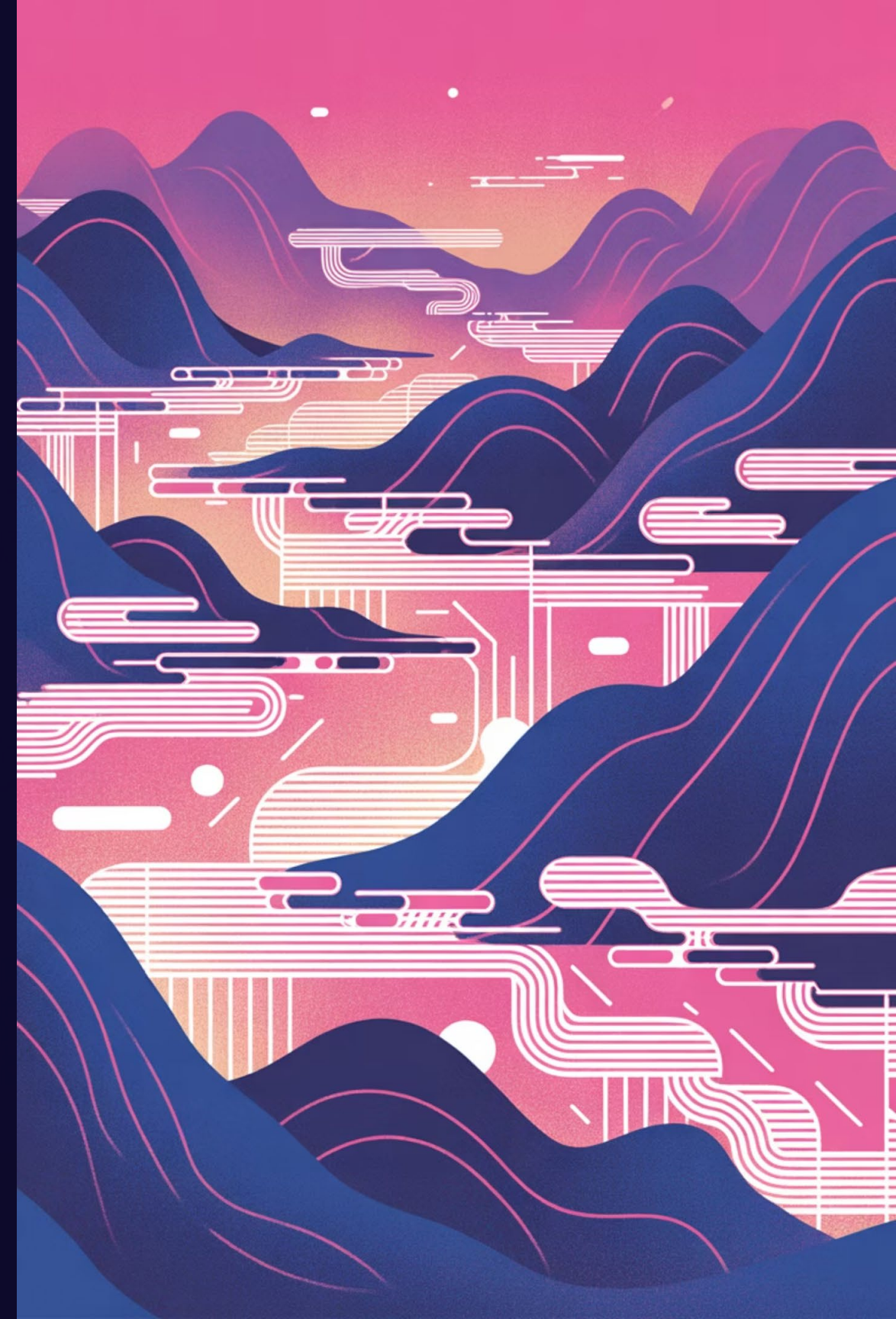


Data Compliance: A Practical Guide

Course Overview

This guide helps you understand and comply with China's data protection laws, focusing on three key areas: the Personal Information Protection Law (PIPL), the Cybersecurity Law (CSL), and requirements for transferring data outside of China.



Part 1: Basic Governance Requirements



Follow Core Data Handling Principles

What it means: Every time you collect or use personal information in China, you must follow three principles:

- **Legality:** Have a legal basis for what you're doing
- **Propriety:** Handle data appropriately and fairly
- **Necessity:** Only collect what you actually need



In Practice

- Don't collect more data than necessary for your business purpose
- Be clear about why you need each piece of information
- Choose methods that have the least impact on people's privacy
- Keep data accurate to avoid harming individuals

 **Why it matters:** This prevents excessive data collection and protects both individual rights and national security.

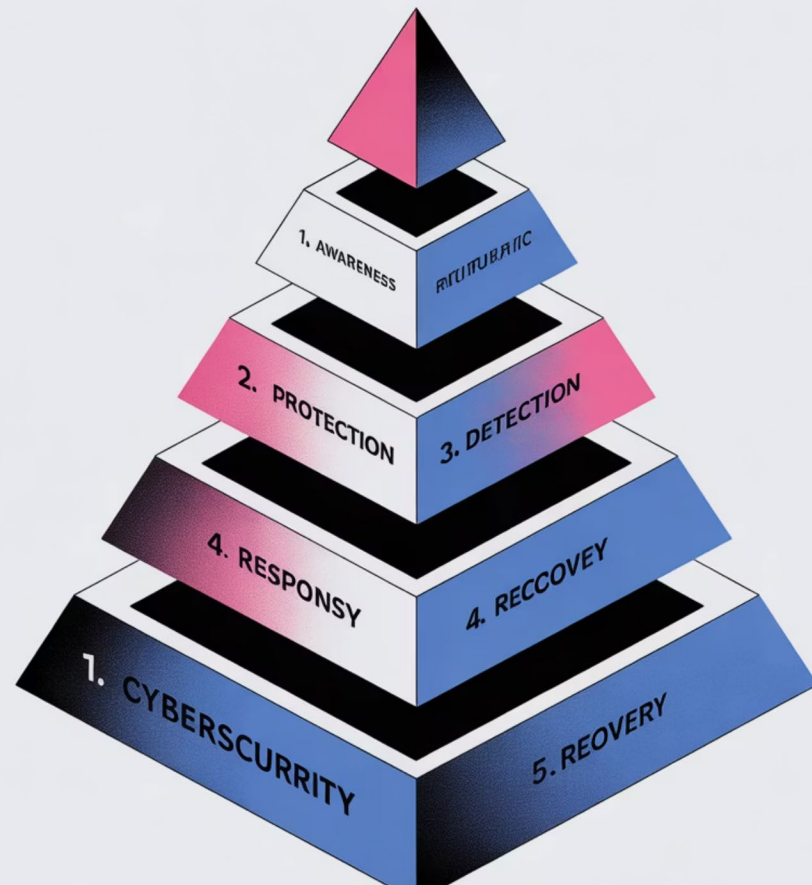
Implement the Multi-Level Protection Scheme (MLPS)

What It Means

If you operate networks or provide online services in China, you must meet cybersecurity standards based on a classification system (MLPS levels 1–5, with higher numbers requiring stricter controls).

In Practice

- Assess what MLPS level applies to your systems
- Implement security controls appropriate to that level
- Register with authorities and undergo periodic assessments
- Maintain documentation of your security measures



Why it matters: This ensures baseline cybersecurity protection and helps you respond effectively to security incidents.

Conduct Regular Compliance Audits

01

Schedule audits at least annually

02

Review all personal information processing activities

03

Check compliance against relevant regulations

04

Document findings and remediation actions

05

Keep audit records for at least 3 years

Proactive audits help you catch and fix problems before regulators find them, demonstrating due diligence.



Clarify Joint Processing Responsibilities



Identify Joint Processing

Find all scenarios where you jointly process data with another organisation



Create Written Agreements

Specify each party's responsibilities and ensure individuals can exercise their rights



Accept Joint Liability

Remember: both parties are jointly liable even with the agreement in place

What it means: If you share data handling responsibilities with another organisation, you need a clear written agreement about who does what.

Part 2: Risk Assessments (PIPIA)

Conduct Impact Assessments for High-Risk Activities

What it means: Before engaging in activities that significantly affect individuals—especially transferring data abroad—you must perform a Personal Information Protection Impact Assessment (PIPIA).

Identify High-Risk Activities

- Transferring personal data overseas
- Processing sensitive data at scale
- Using data in ways that significantly affect individuals
- Public disclosure of personal information

Document Key Elements

- Whether your purpose and methods are lawful and necessary
- How it impacts individual rights
- What protective measures you've implemented
- Whether those measures match the risk level

This demonstrates you've thoughtfully considered risks before proceeding with sensitive data activities.

Keep PIPIA Records for 3+ Years

What it means: All PIPIA reports and processing records must be retained for at least three years.



- 1 Store PIPIA documentation securely
- 2 Include assessment reports, supporting evidence, and processing records
- 3 Make them readily available for regulatory inspection
- 4 Update assessments when circumstances change

□ These records prove to regulators that you took appropriate precautions.

Apply Extra Protection for Sensitive Data

What it means: Certain types of personal information require higher protection and separate, explicit consent.



Biometric Information

Fingerprints, facial recognition, voice patterns



Financial Information

Banking details, payment records, transactions



Location Data

GPS coordinates, movement tracking, geolocation



Health Records

Medical history, diagnoses, treatment information



Religious Beliefs

Faith affiliation, practices, spiritual information



Personal Identity Documents

Passport, ID card, driving licence numbers

In Practice

- Identify all sensitive data in your systems
- Obtain separate, explicit consent before processing
- Apply stronger security controls
- Limit access to authorised personnel only
- Minimise collection and retention periods



Part 3: Cross -B order Data Transfers

Determine If You Need a Security Assessment

What it means: You must apply to the Cyberspace Administration of China (CAC) for approval before transferring certain data abroad.



You're a CIIO

Critical Information Infrastructure Operator status triggers mandatory assessment



Volume Thresholds

You transfer data exceeding volume thresholds set by CAC



Important Data

Data affecting national security, economy, or public interest requires approval



Security Impact

Your activities affect or may affect national security concerns

❑ Transferring data without required approval can result in severe penalties.

Complete a Self -Assessment First

Before filing for an official security assessment, you must conduct your own risk assessment of the planned data transfer.



Your Self -Assessment Must Evaluate:

- ▾ Whether the transfer is legal, legitimate, and necessary
- ▾ Risks to national security and individual rights
- ▾ Whether the overseas recipient can adequately protect the data
- ▾ How individuals can exercise their rights regarding transferred data
- ▾ Problems identified and corrective measures taken

Prepare Complete Application Documentation

What it means: Your security assessment application must include comprehensive information about the data transfer.

Letter of Commitment

Formal declaration of compliance intentions

Application Form

Business scenarios, purposes, transfer methods, and data flow details

Data Specifications

Types and volume of data, recipient information

Security Measures

Technical and organisational safeguards implemented

Self-Assessment Report

Your comprehensive risk evaluation and mitigation plan

In practice: Use official CAC forms, be thorough and accurate—incomplete applications will be rejected. Provide clear explanations of business necessity and include technical details about data flows.

Establish Strong Contractual Protections

What it means: You must have a legally binding contract with the overseas recipient that specifies data protection obligations.

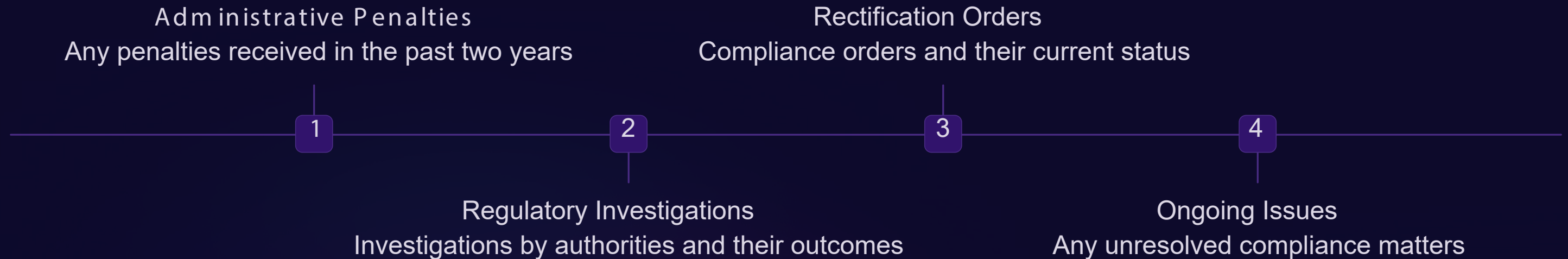
1	2
Data Security Protection Responsibilities Clear obligations for safeguarding transferred information	Specific Handling Obligations Detailed requirements for processing transferred data
3	4
Individual Rights Protection Mechanisms ensuring people can exercise their rights	Data Breach Notification Procedures for reporting and responding to incidents
5	6
Chinese Law Compliance Requirements to comply with applicable regulations	Audit Rights and Remedies Provisions for verification and enforcement of obligations

In Practice

- Use standard contractual clauses where available
- Have legal counsel review agreements
- Ensure overseas recipients understand and accept obligations
- Include provisions for Chinese individuals to enforce their rights



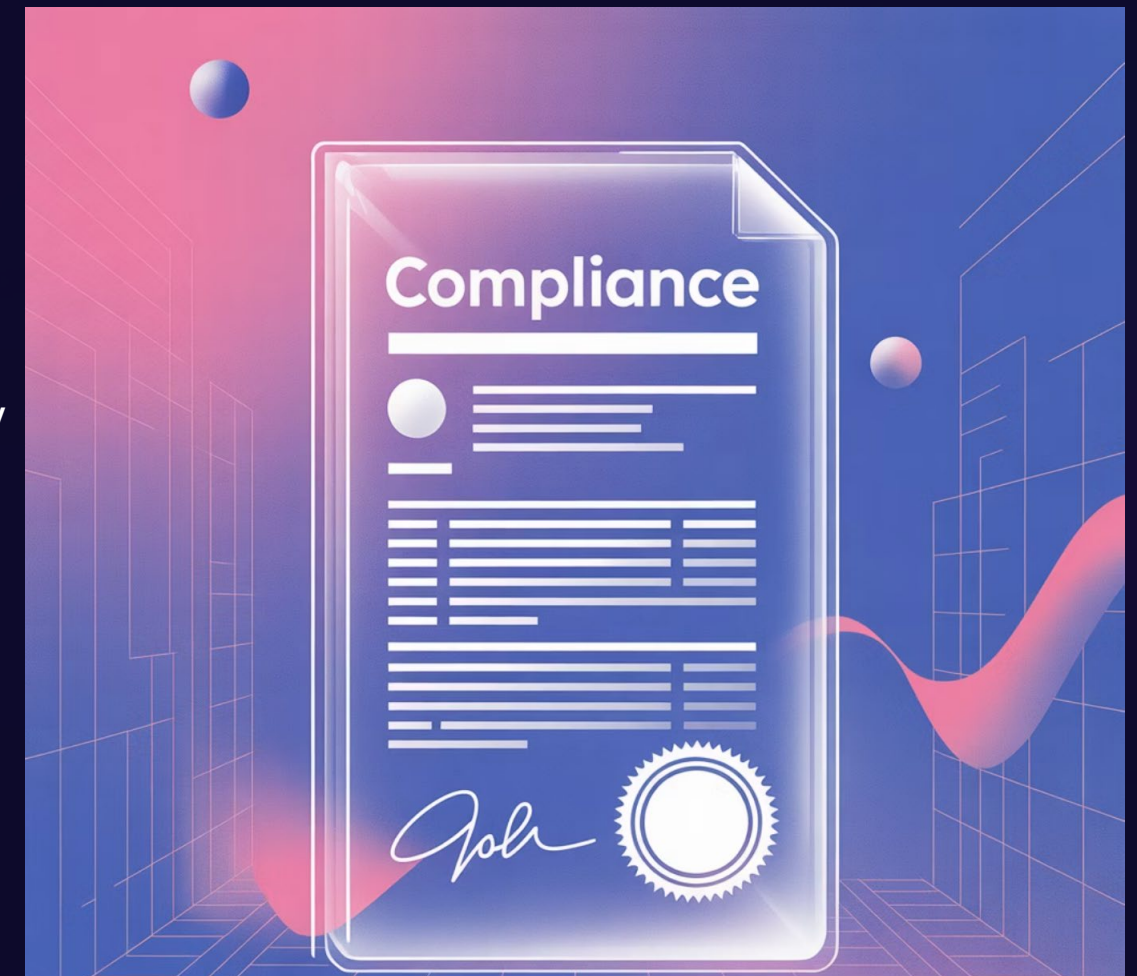
Disclose Your Compliance History



In Practice

Be completely transparent—regulators can verify this information independently. Explain what corrective actions you've taken to demonstrate improved compliance posture. Don't hide or minimise past issues, as this will undermine your credibility.

- This allows CAC to assess your overall compliance track record and reliability as a data handler.



Quick Compliance Checklist



Before Launching Operations in China

- Understand PIPL principles and apply them to all data handling
- Determine your MLPS level and implement required controls
- Establish audit procedures and schedule
- Document any joint processing arrangements

For Ongoing Operations

- Conduct PIIPAs for all high-risk activities
- Maintain 3+ year records of assessments
- Apply extra protections to sensitive data
- Review data handling practices regularly

Before Any Cross -Border Transfer

- Check if mandatory security assessment applies
- Complete thorough self-assessment
- Prepare comprehensive application documents
- Establish contractual protections with recipients
- Obtain necessary approvals before transfer